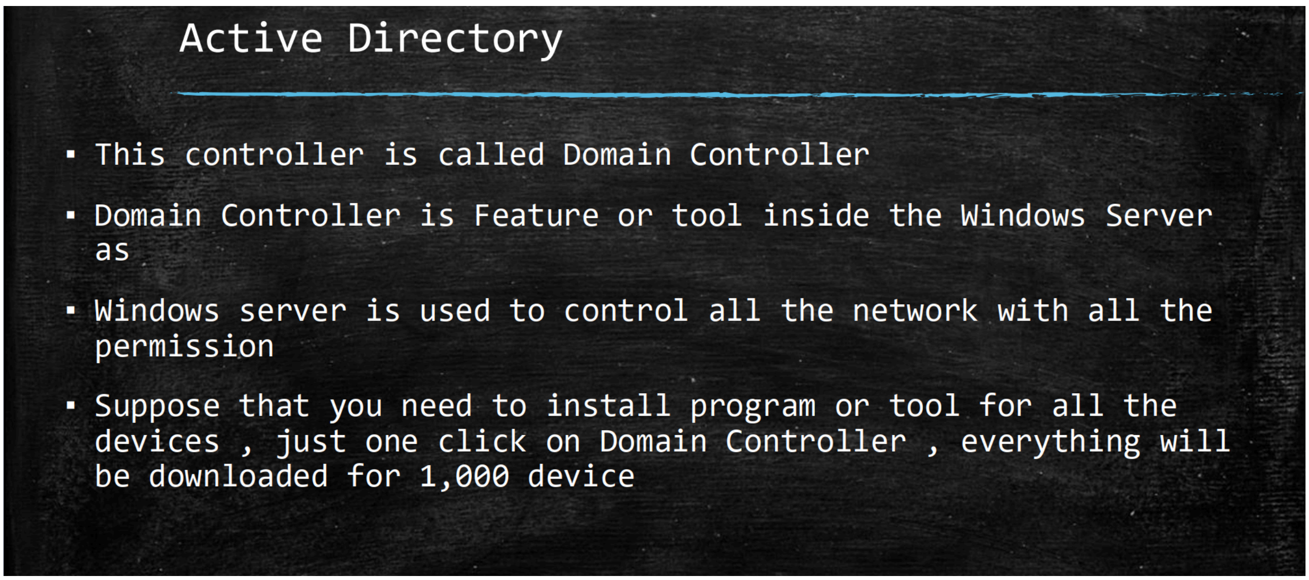
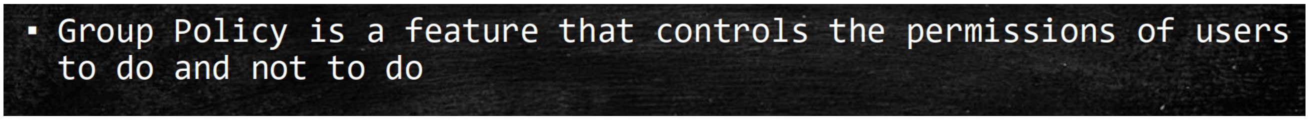
Active Directry

- ما هوه ال Active Directry
  - هوه Domain controler بيتحكم ف كل اجهزه الشركه من جهاز واحد اساسي
  - لو شركة فيها 500 موظف:
    - من غير AD → لازم مسؤول الشبكة يروح لكل جهاز يعمل حساب ويديله صلاحيات.
    - مع AD → بيتعمل حساب واحد للمستخدم في الـ AD، وأيًا كان الجهاز اللي يدخل منه، يلاقي نفسه عنده نفس الصلاحيات.

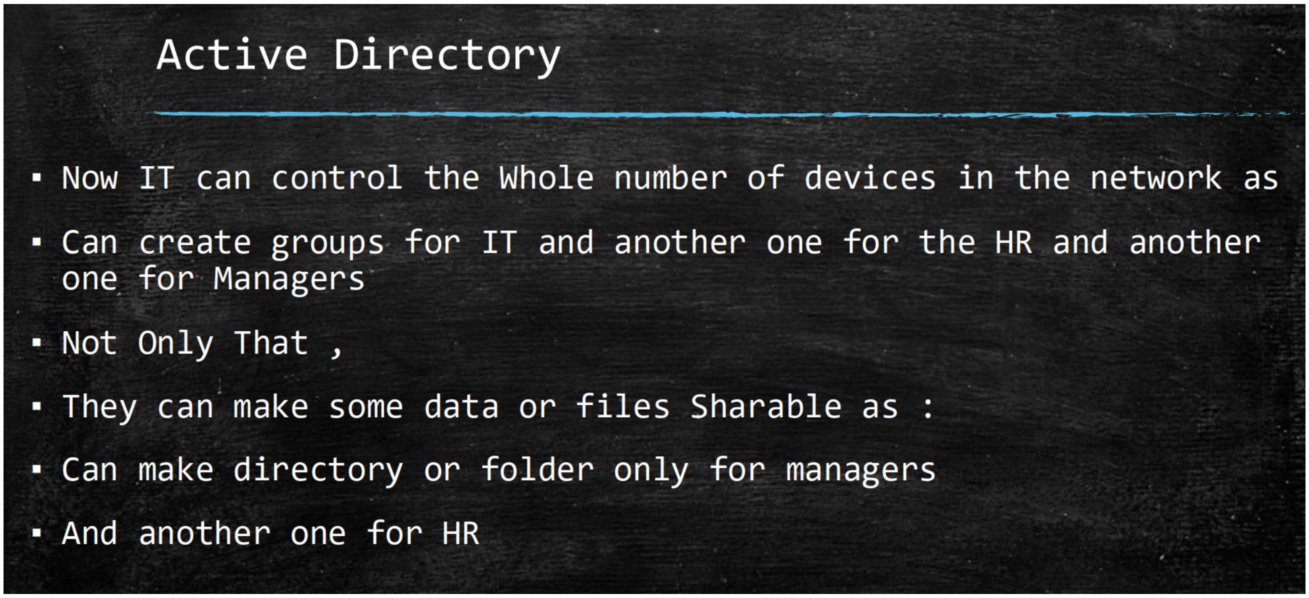
- 

- الـ Domain controler دا يعتبر العقل المدبر للشركه المدير بمعني اصح
  - بيبقي عباره عن اداه داخل ال Windows Server
    - ليه اصدارات كتير اشهرهم 2008 , 2012 , 2016 , 2022 , 2025
- لسيرفر ده بيتحكم في كل الأجهزة اللي متوصلة بالشبكة، سواء صلاحيات أو إعدادات أو برامج.

-
  - الـ LDAP دا بروتوكول داخل Active Directry
- الـ Windows Server فيه مميزات أساسية:
- الـActive Directory (التحكم في الأجهزة واليوزرات)
- الـ **Kerberos** (بروتوكول أمان بيأكد إن اليوزر هو فعلاً الشخص الصح)



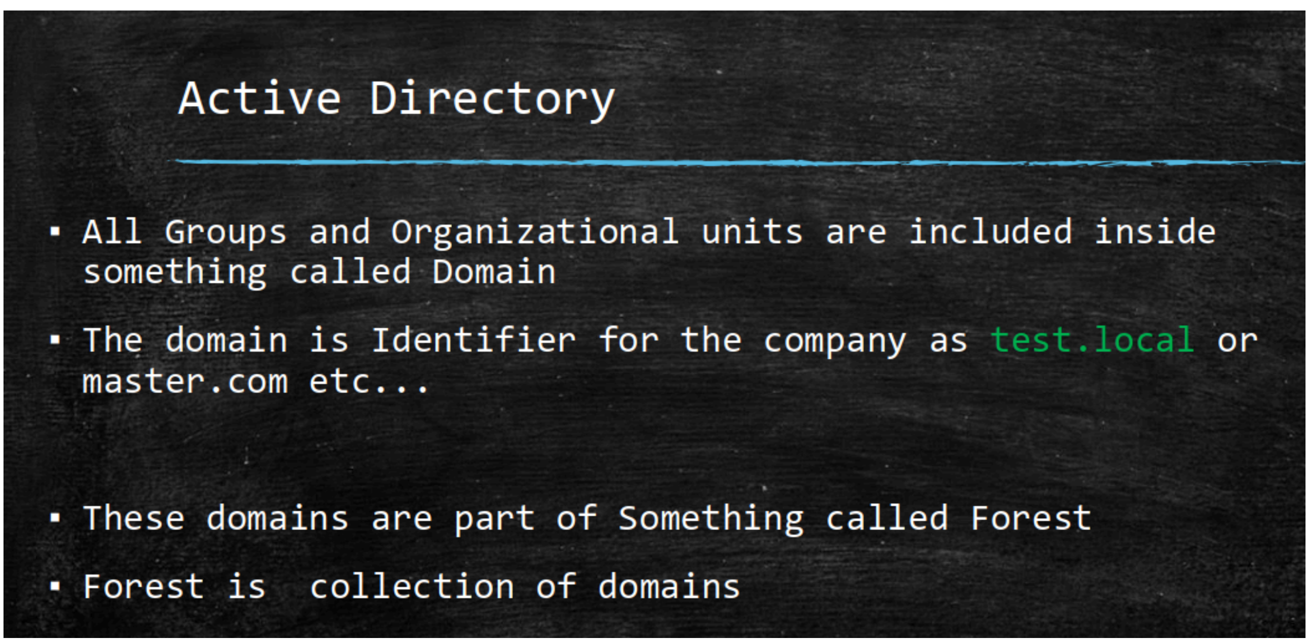
- في ميزة اسمها **Group Policy**، ودي اللي بتحدد كل يوزر يقدر يعمل إيه وميقدرش يعمل إيه



- الـ IT يقدر يتحكم في كل الأجهزة اللي موجودة على الشبكة.
- يقدر يعمل **Groups** زي مجموعة للـ IT، ومجموعة للـ HR، ومجموعة للمديرين.
- كمان يقدر يحدد مين يشارك بيانات أو ملفات معينة.
- مثلاً: يعمل فولدر يفتح للمديرين بس، أو فولدر تاني للـ HR بس.

- 

- كل جروب من دول اسمه Organizational Unit
- ال Domain policy دي بتتحكم كل واحد يعمل اي
- يعني لو أحمد من HR ← يتحط في OU بتاعت HR
- وبالتالي هياخد صلاحيات الـ HR كلها

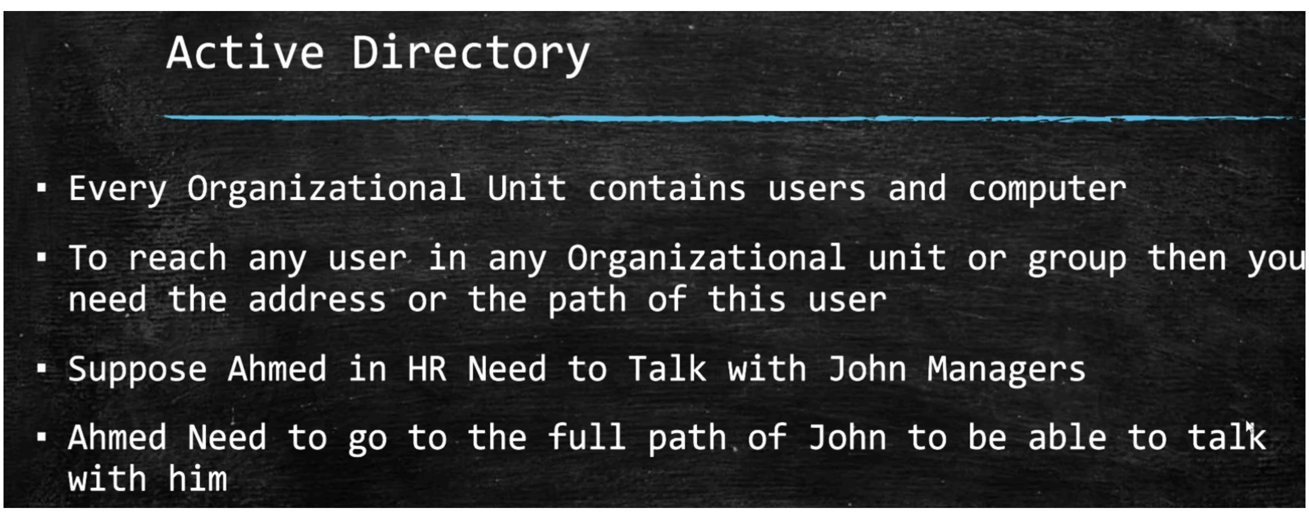
- 

- الـ OUs كلها بتبقى جوه **Domain**
- الدومين ده بيمثل الشركة (زي `test.local`)

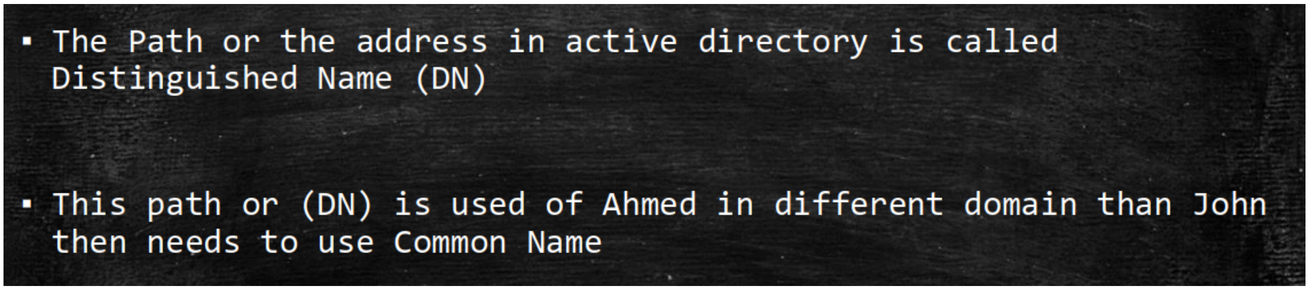
- ولو عندك كذا دومين ← بيتجمعوا في حاجة اسمها Forest

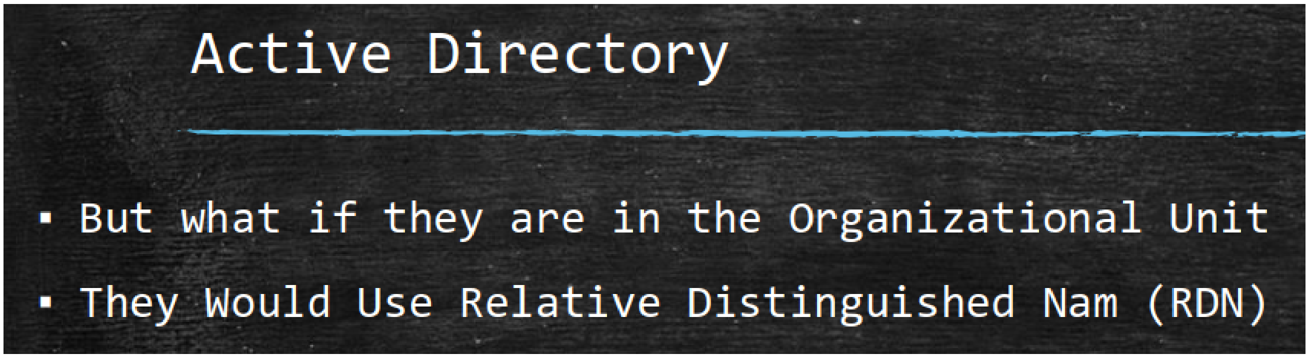
- 

- لو شركتين اندمجوا (زي Facebook و WhatsApp):
- فيسبوك عندها Forest.
- واتساب عندها Forest.
- بيعملوا بينهم **Trust Link** عشان يقدروا يشتغلوا مع بعض.

- 

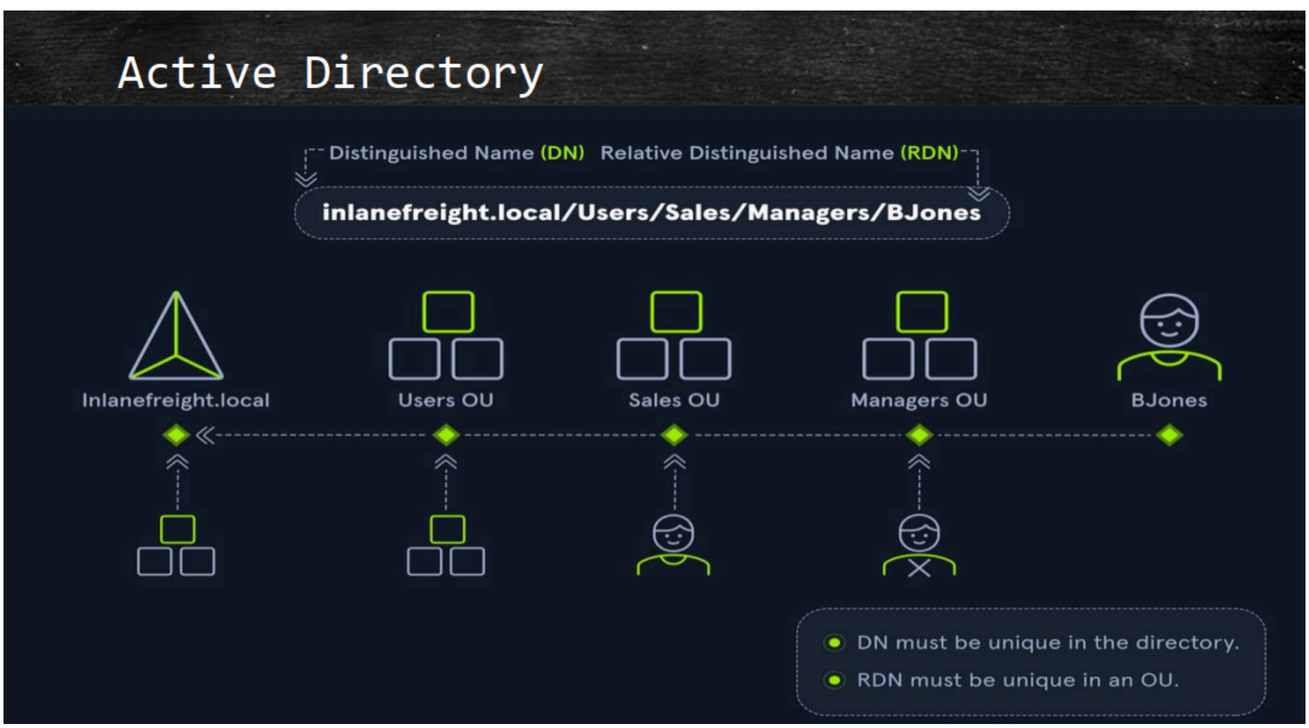
- جوا كل OU فيه يوزرز وأجهزة
- عشان توصل لشخص معين، لازم تعرف العنوان الكامل بتاعه في الـ AD.
- مثال: أحمد (HR) عايز يتواصل مع جون (Manager).

- 

- العنوان الكامل اسمه **Distinguished Name (DN)**.
- ولو كانوا في دومينات مختلفة ← يستخدموا **Common Name (CN)**.
- 

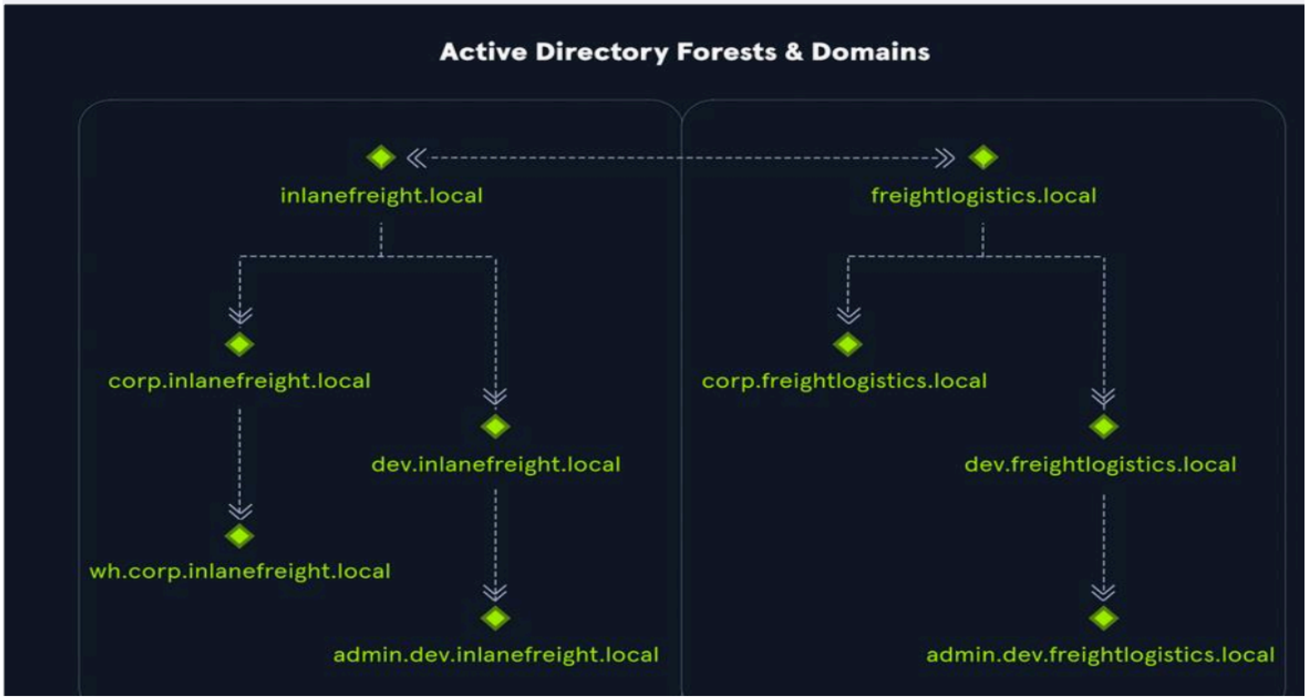
- لو هما في نفس الـ OU ← ممكن يختصروا ويستخدموا **Relative Distinguished
- Name (RDN)**.

> 📎 **نفس حوار ال absolute path وال relative path ف ال linux**

- 

-
- رسمة بتوضح العلاقة بين:

- OU
- Domain
- Forest

- 

- مثال على شركتين:
- `inlanefreight.local`
- `freightlogistics.local`
- إزاي يدمجوا الـ Forests مع بعض.
- لازم الادمن يكتب ال path كامل لان مش نفس الشركه

Active Directory

- Now let's get some definitions

Object:

- An object can be defined as ANY resource present within an Active Directory environment such as OUs, printers, users, domain controllers, etc.

Attributes

Every object in Active Directory has an associated set of attributes used to define characteristics of the given object. A computer object contains attributes such as the hostname and DNS name. All attributes in AD have an associated LDAP name that can be used when performing LDAP queries, such as displayName for Full Name and given name for First Name.

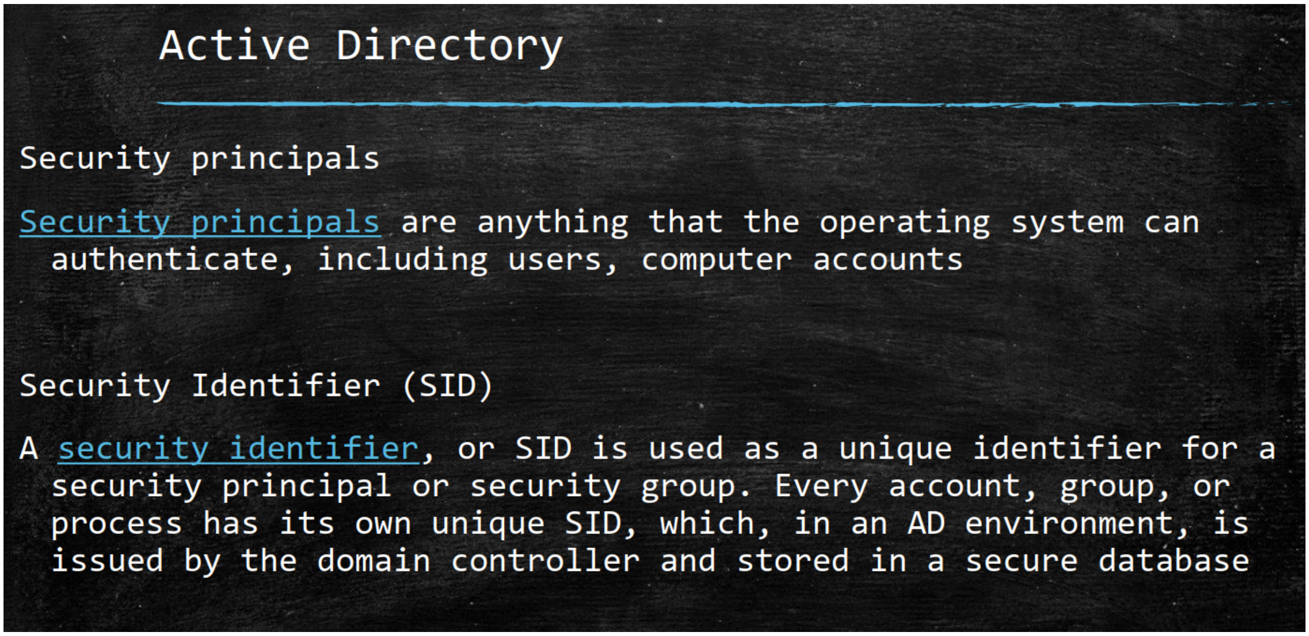
- أي حاجة جوا Active Directory اسمها **Object** (زي يوزر، جهاز، برنتر، OU...).
- كل Object ليه **Attributes** (خصائص) بتوصفه.
  - مثال: جهاز كومبيوتر له Hostname و DNS name.
  - كل Attribute ليه اسم في LDAP زي `displayName` (اسم العرض) أو `givenName` (الاسم الأول).

Active Directory

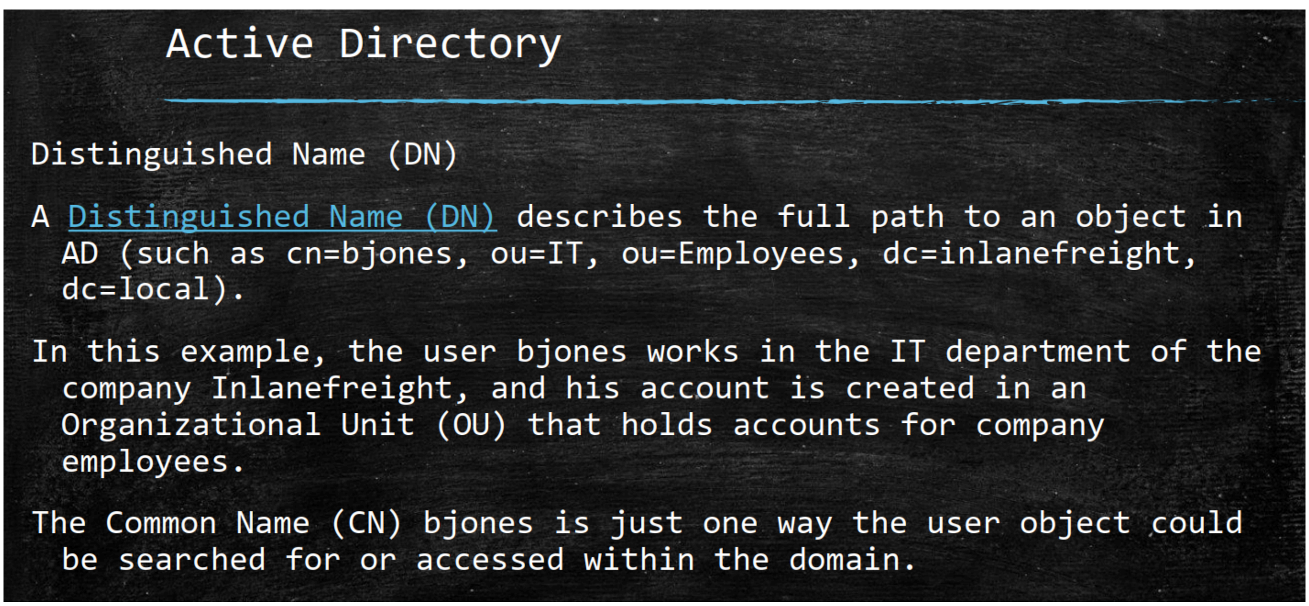
Domain : is a logical group of objects such as computers, users, OUs, groups, etc. We can think of each domain as a different city within a state or country. Domains can operate entirely independently of one another or be connected via trust relationships.

Forest : is a collection of Active Directory domains. It is the topmost container and contains all of the AD objects introduced below, including but not limited to domains, users, groups, computers, and Group Policy objects. A forest can contain one or multiple domains and be thought of as a state in the US or a country within the EU. Each forest operates independently but may have various trust relationships with other forests.

- الـ **Domain** = مجموعة Objects زي مدينة.
- الـ **Forest** = مجموعة Domains زي دولة.
- الـ Domains ممكن تشتغل لوحدها أو يبقى فيه **Trust** بينهم.



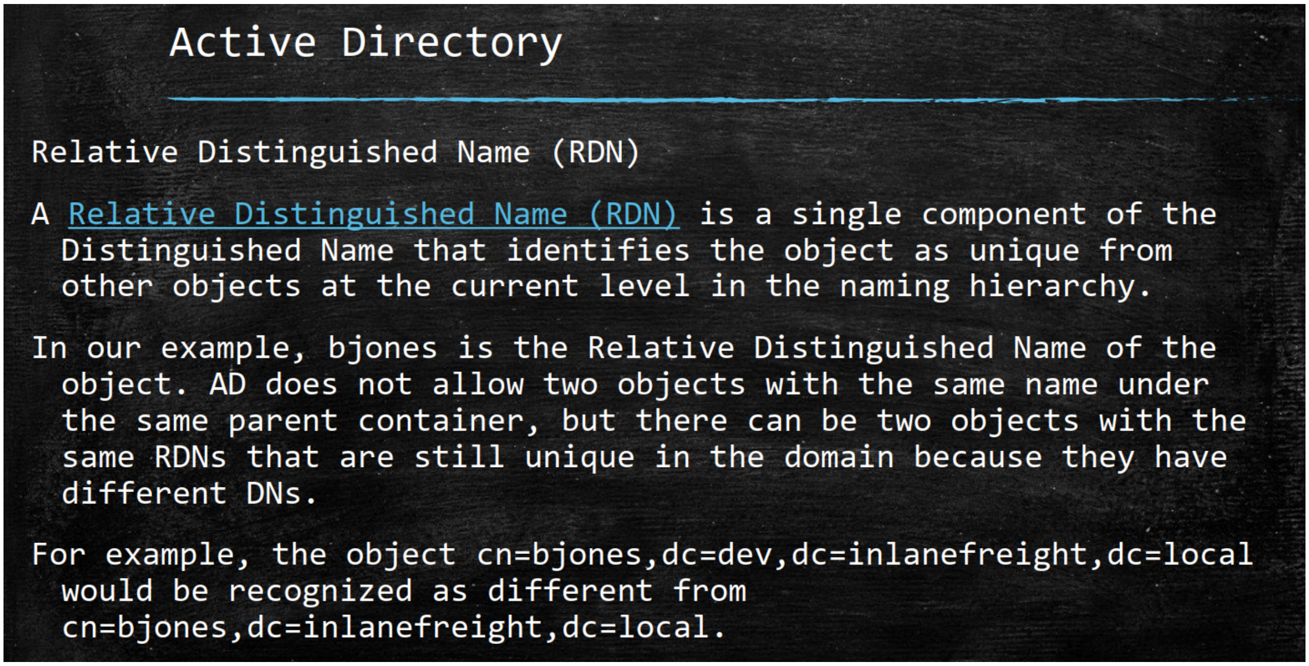
- الـ **Security Principal** = أي حاجة السيستم يقدر يعملها Authenticate (يوزر أو جهاز).
- كل واحد ليه **SID – Security Identifier** زي الرقم القومي.
- الـ Domain Controller هو اللي بيصدر الـ SID ويحفظه.



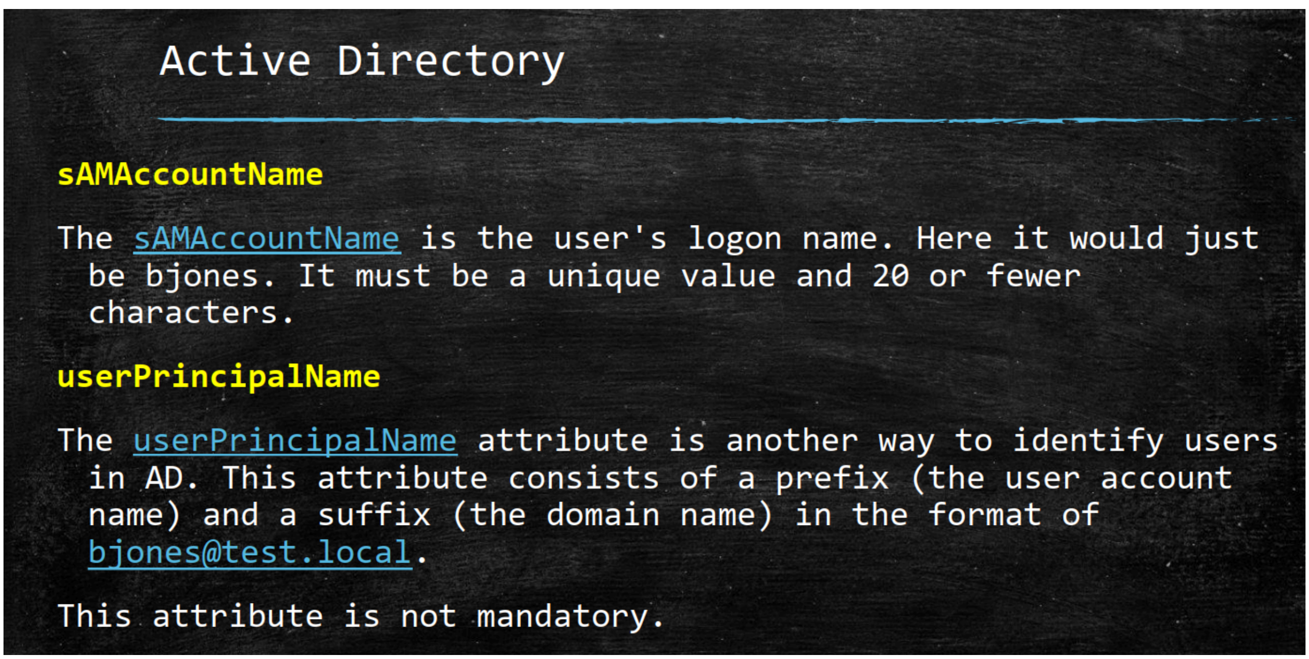
- **DN** = العنوان الكامل لأي Object جوا AD.
- مثال:

```
cn=bjones, ou=IT, ou=Employees, dc=inlanefreight, dc=local
```

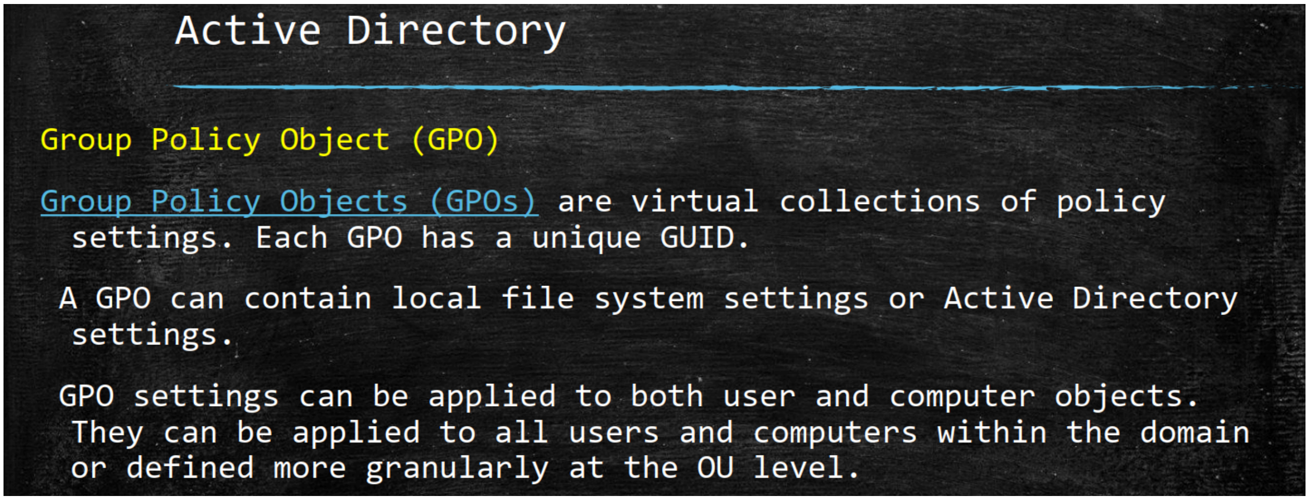
- ده معناه: الموظف bjones في OU IT اللي جوا OU Employees في الدومين inlanefreight.local.
- **CN (Common Name)** = الاسم اللي نستخدمه للبحث جوه الدومين.



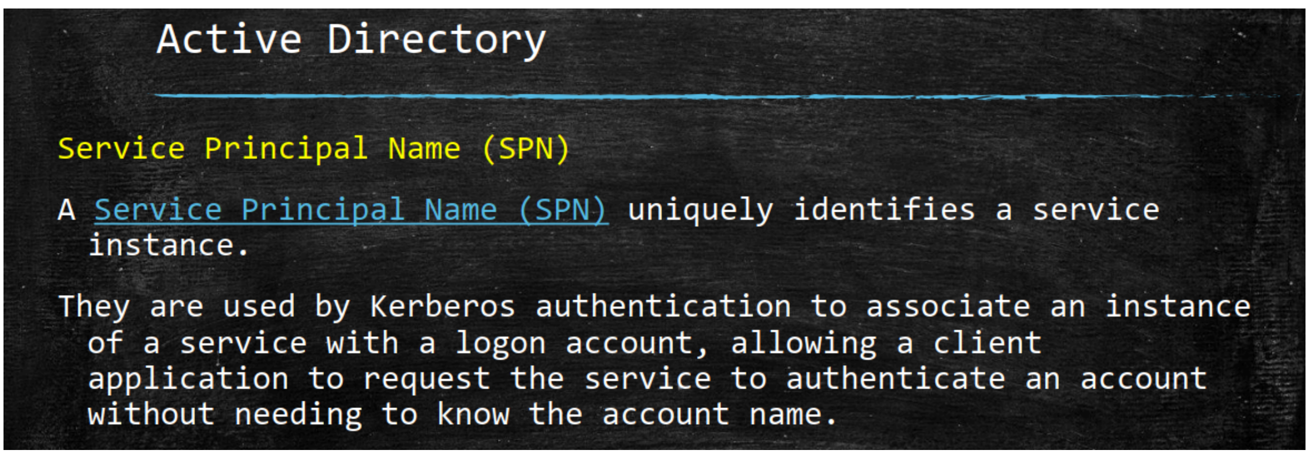
- **RDN** = جزء من الـ DN يميز Object واحد في المستوى الحالي.
  - ما ينفعش يبقى فيه اتنين بنفس الـ RDN في نفس المكان.
  - لكن ممكن يكون فيه اتنين بنفس الاسم في أماكن مختلفة (عشان DN كامل مختلف).



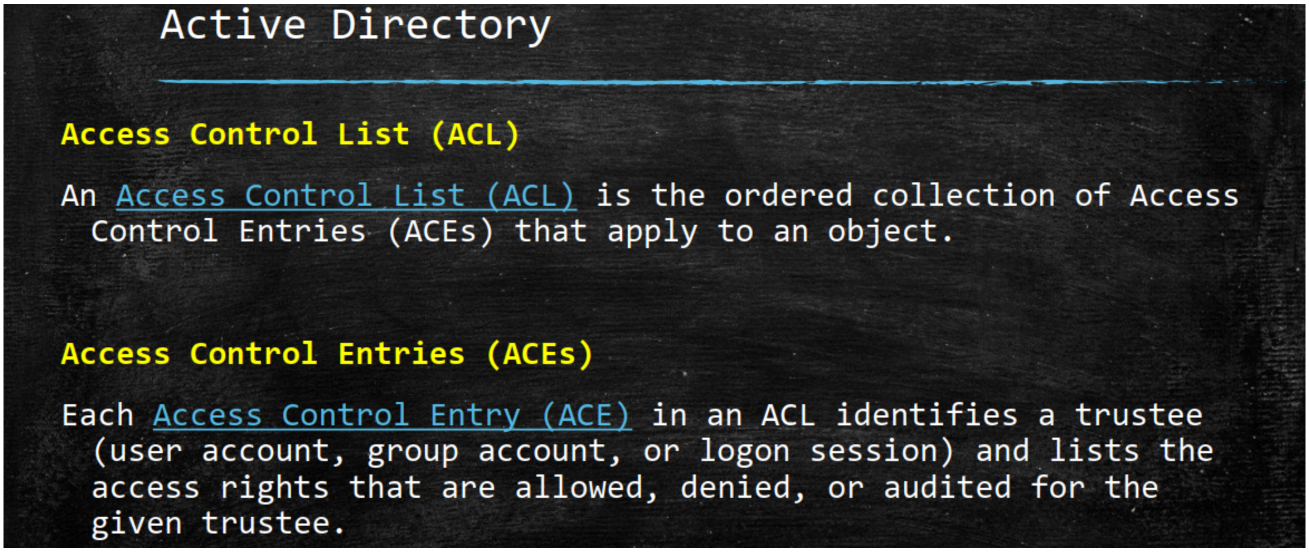
- **sAMAccountName**: اسم الدخول القديم، قصير (20 حرف كحد أقصى)، لازم يكون Unique.
- **UPN – userPrincipalName**: شكل حديث لتسجيل الدخول `username@domain`.
  - مثال: `bjones@test.local`.



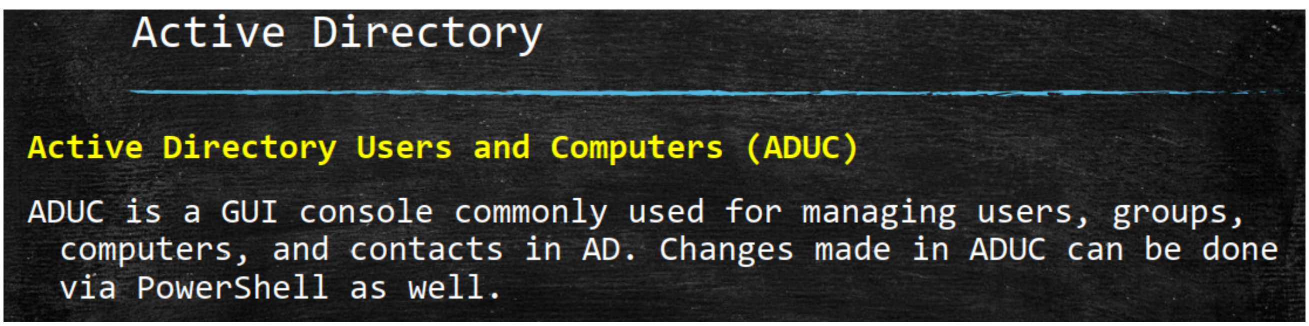
- الـ **GPO** = مجموعة سياسات وصلاحيات.
- بتتحكم في اليوزرز والأجهزة.
- ممكن تتطبق على الدومين كله أو OU معينة.
- مثال:
  - منع يوزر يغير Wallpaper.
  - منع تشغيل برنامج معين.



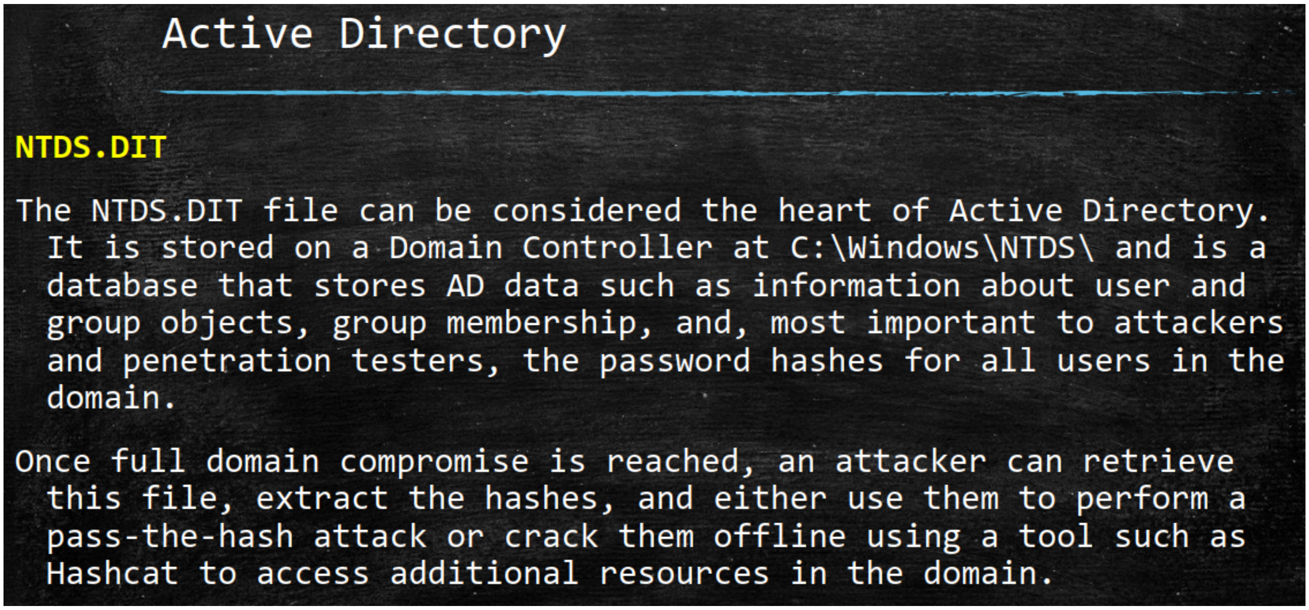
- الـ **SPN** = اسم يميز خدمة معينة جوا الشبكة.
- بيستخدمه Kerberos عشان يعرف الخدمة دي مربوطة بأي حساب.
- مثال: IIS أو SQL Server لازم يكون ليهم SPN.



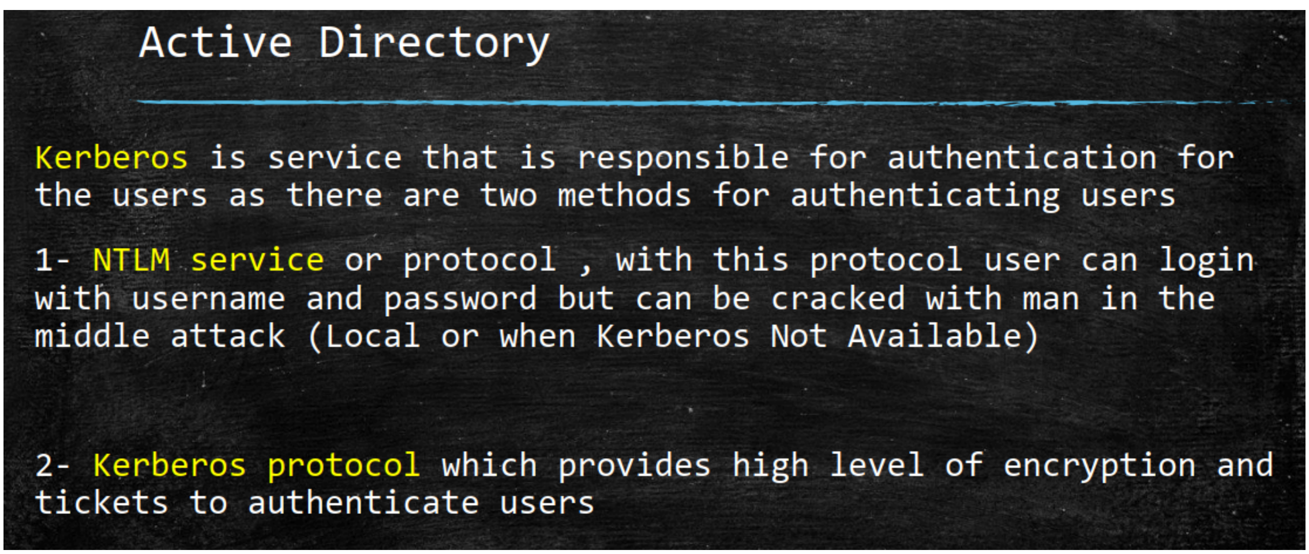
- **ACL – Access Control List** = قائمة صلاحيات لأي Object.
- جواها **ACE – Access Control Entry**.
- كل ACE بيحدد:
  - مين (يوزر أو جروب).
  - إيه الصلاحيات المسموحة أو المرفوضة.



- الـ **ADUC – Active Directory Users and Computers**.
- أداة رسومية لإدارة اليوزرز والجروبات والأجهزة.
- نفس التعديلات ممكن تتعمل باستخدام PowerShell.

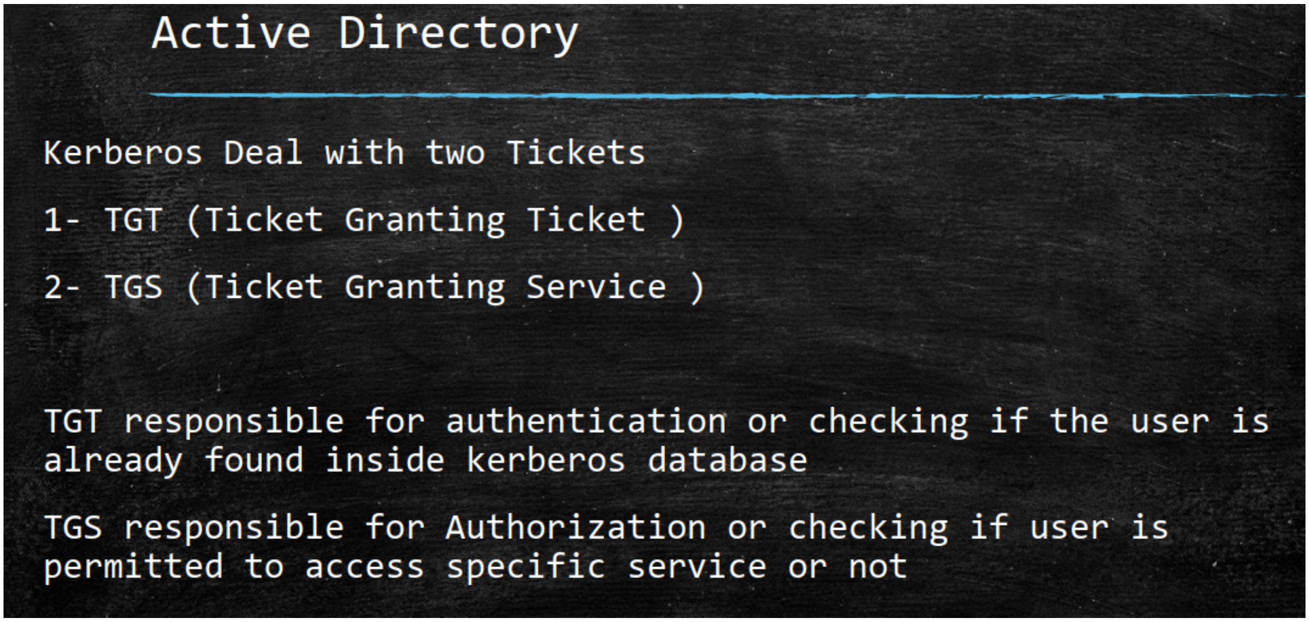


- ده الملف الأساسي بتاع Active Directory.
- مكانه: `C:\Windows\NTDS\`.
- بيخزن:
  - بيانات يوزرز.
  - بيانات جروبات.
  - عضويات.
- Password Hashes (أهم حاجة).
- الهاكر لو وصله يقدر يعمل هجمات زي Pass-the-Hash أو يفك الـ Hashes بأدوات زي Hashcat.



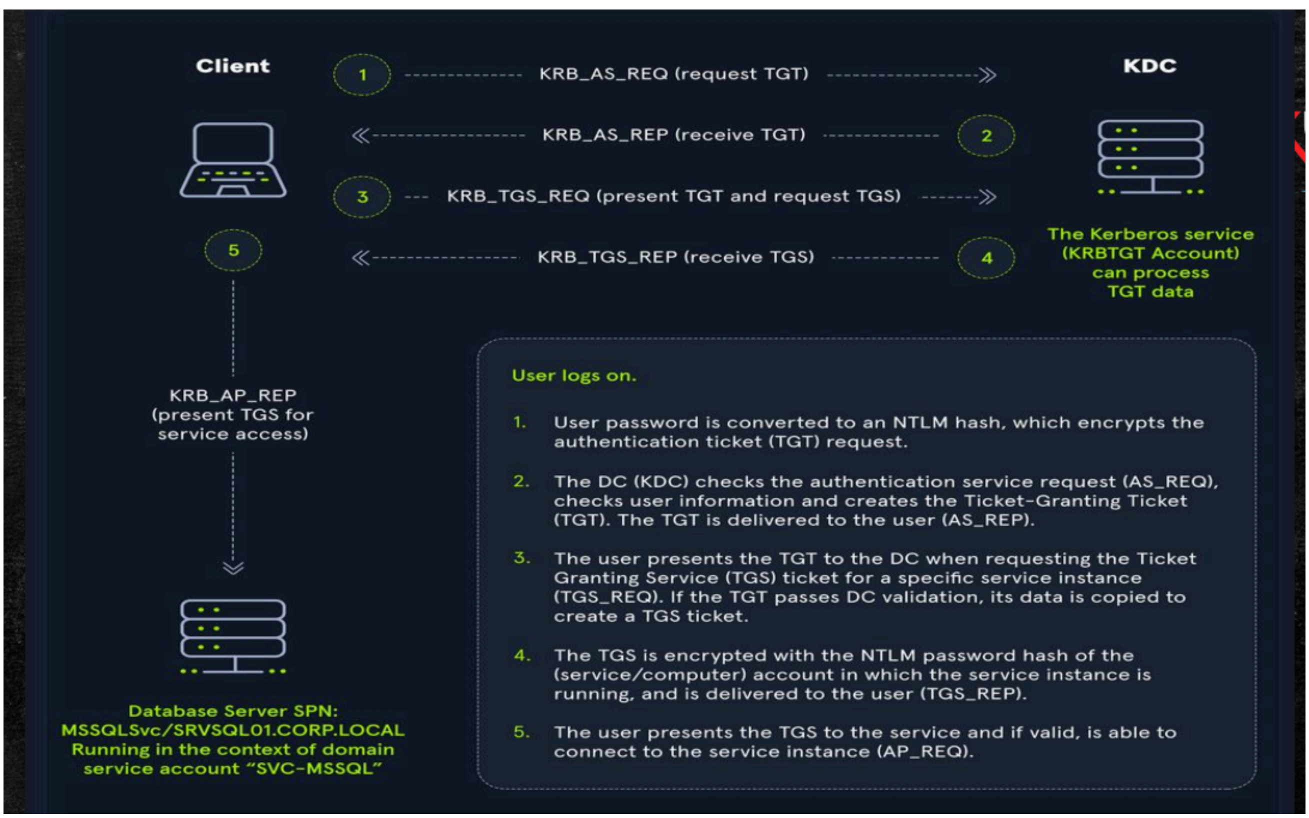
- طريقتين أساسيين للمصادقة:

1. **NTLM**: قديم، بيعتمد على Username + Password، ضعيف وسهل يتكسر.
2. **Kerberos**: أحدث وأقوى، بيعتمد على **Tickets** وتشفير.

- 

- نوعين تذاكر:

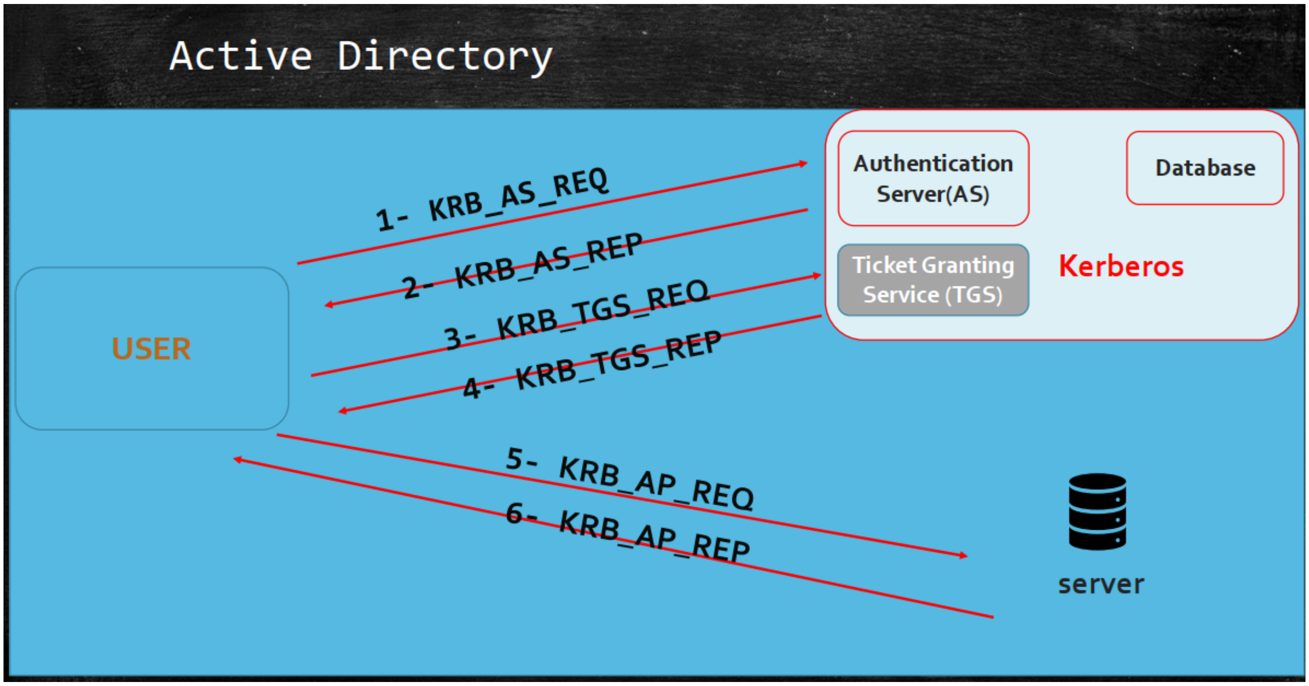
1. **TGT – Ticket Granting Ticket**: يتأكد إن اليوزر موجود في قاعدة البيانات.
2. **TGS – Ticket Granting Service**: يتأكد من صلاحيات اليوزر على خدمة معينة.

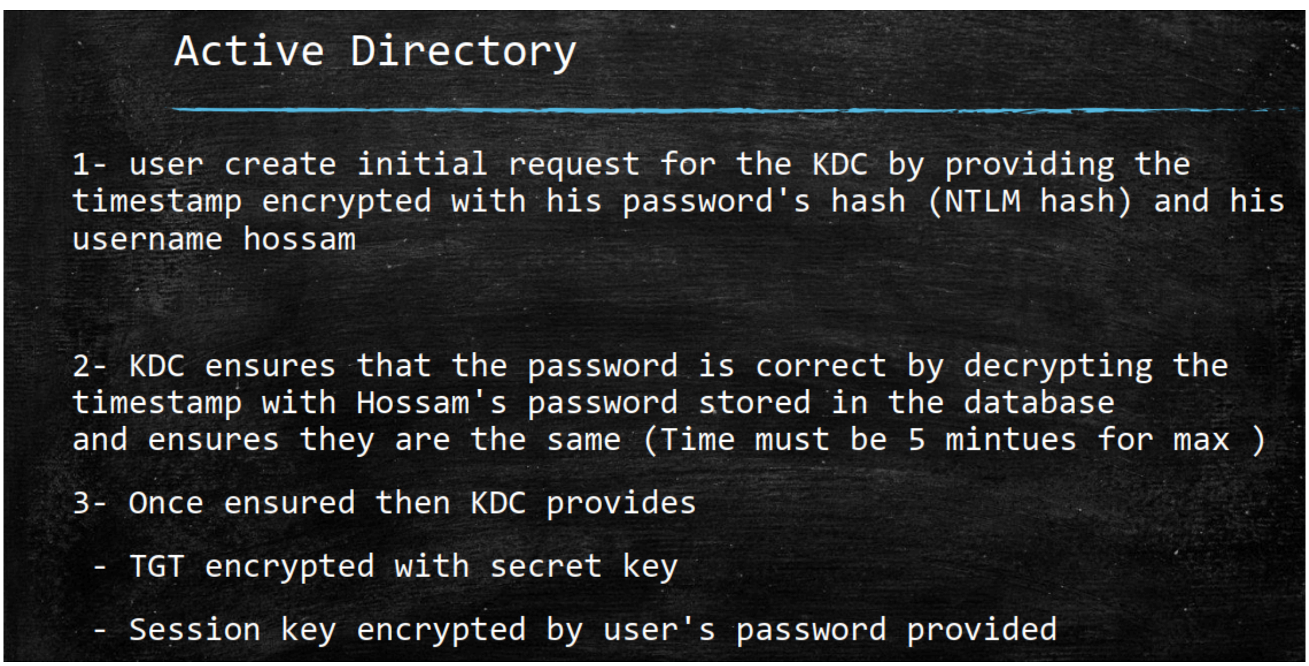
- 

- المكونات:

- Authentication Server (AS).
- Database.
- Ticket Granting Service (TGS).

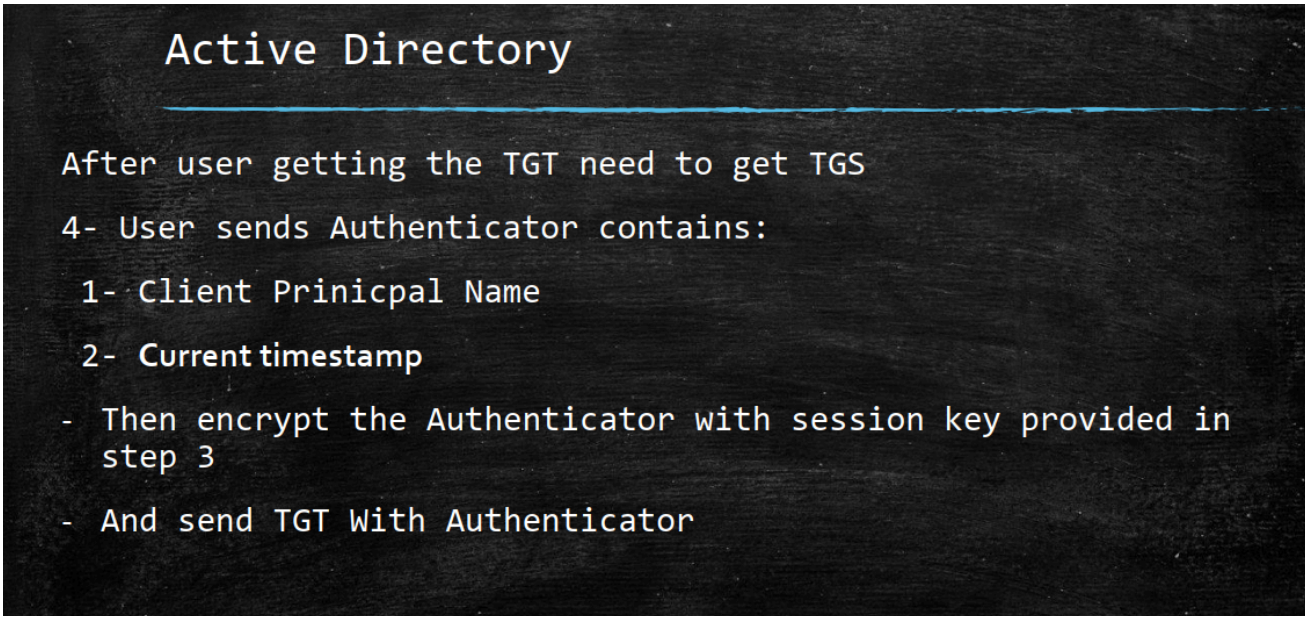
- User.

- 

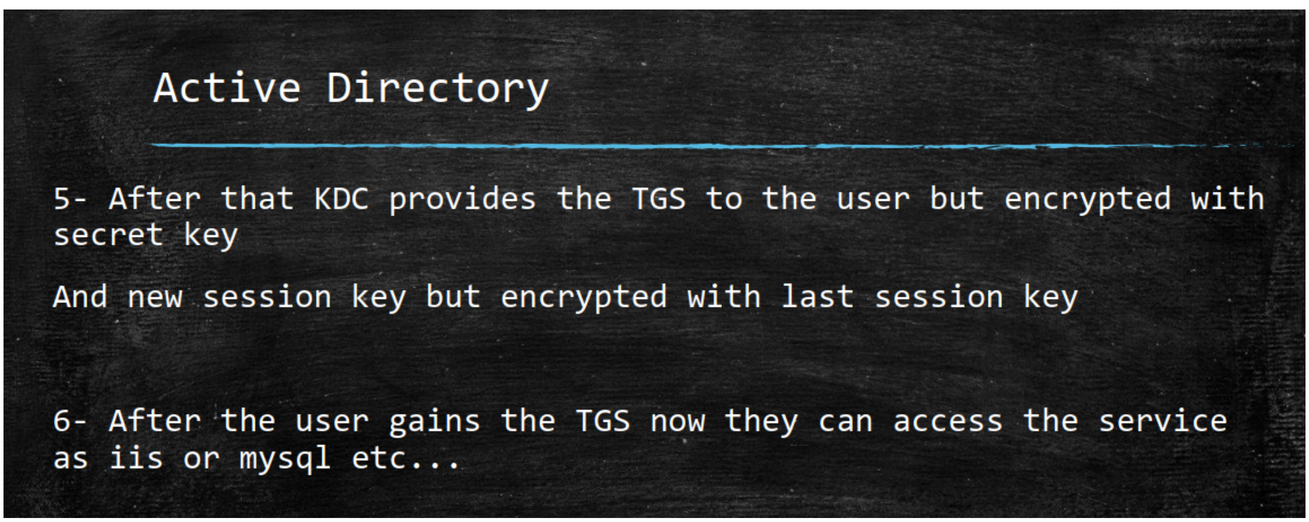
- 

1. اليوزر يطلب من KDC تذكرة: يبعت Username + Timestamp متشفر بالـ Hash بتاع الباسورد.
2. الـ KDC يفك التشفير ويتأكد من صحّة الباسورد. لازم فرق التوقيت ≤ 5 دقايق.
3. لو صح → KDC يدي اليوزر:

- TGT متشفر بمفتاح سري.
- Session Key متشفر بباسورد اليوزر.



4. اليوزر عايز خدمة (مثلاً IIS).
   - يجهز **Authenticator** فيه اسمه + Timestamp جديد.
   - يشفره بالـ Session Key اللي معاه.
   - يبعت TGT + Authenticator للـ KDC.



5. KDC يرد:
   - TGS متشفر بمفتاح سري.
   - Session Key جديد متشفر بالـ Session Key القديم.
6. اليوزر دلوقتي معاه TGS → يقدر يدخل على الخدمة.